Gate 08 Prerequisites — BA Analysis

Date: 2026-04-17 **Scope:** Sharpen two of four Gate 08 prerequisites: (1) coordinator persona set and (2) threat model for Tier 3/4 scoping. Input to PM and Architecture agents. **Builds on, does not restate:** `CLAUDE.md` (mirror policy, tier model), `docs/planning/business-analysis/gate-07-reconciliation.md` §4 (handoff risks 2, 3, 5), `docs/planning/business-analysis/conservation-status-governance.md` (manual-expert flow — canonical authenticated-editing example), `docs/planning/architecture/gate-07-frontend-architecture.md` "Deferred". **Framing shift:** Aleksei re-scoped Gate 08 from "coordinator read-only dashboards" to **on-site authenticated CRUD**. Persona work below identifies *which entries each persona edits* and *the friction that currently drives them to spreadsheet round-trips*.

Section 1 — Coordinator persona set

Five candidate personas. Each is a composite from the stakeholder universe already named in `conservation-status-governance.md`, the ECA Workshop audience, and the CARES/SHOAL/IUCN-SSC ecosystem. None are invented — all map to real actors Aleksei has identified in prior docs or will meet at the workshop. Where a persona's editing needs don't fit the current 5-tier model, that gap is flagged explicitly.

Persona A — Zoo Population Manager ("Claudia-type")

Attribute	Value
Role	Studbook keeper / curator at EAZA/AZA member institution
Tier	4 (Program Manager), scoped to their institution
Institution type	`zoo` / `aquarium`
Entities edited	`ExSituPopulation` (count_total/male/female/breeding_status), `HoldingRecord` (monthly census), `BreedingEvent`, `Transfer` (outbound), genetic diversity notes. **Not** Species taxonomy, **not** ConservationAssessment.
Primary context	Desktop at office, occasionally tablet on the animal-care floor
Friction today	Keeps monthly census in Excel; transcribes into ZIMS; has no second home for Malagasy-cichlid-specific breeding coordination. MFFCP is a *third* transcription target unless data entry is faster than Excel+ZIMS combined.
Approval flow	Self-service for own institution's records; no second pair of eyes required. Transfers auto-create a *pending* inbound record at the receiving institution that their counterpart accepts.
Volume	5–20 edits/week per institution; spike at quarterly census and transfer events

Tier-model fit: **clean.** Tier 4 institution-scoped CRUD is exactly this persona.

Persona B — CARES Hobbyist Breeder ("Rashel-type")

Attribute	Value

Role	Private breeder in a CARES/Citizen Conservation program, often no institutional affiliation
Tier	**Gap** — needs Tier 3 equivalent editing rights on their *own* population records, but has no `Institution` FK today
Institution type	`hobbyist_program` (exists in enum, but typically one person = one "institution")
Entities edited	`ExSituPopulation` for their own holdings, `BreedingEvent`, outbound `Transfer` (to another breeder or zoo). Sees aggregate data for species they work with.
Primary context	Personal laptop evenings, phone in the fishroom (light data entry only — counts, breeding events)
Friction today	Spreadsheet + Facebook group messages. Data never reaches coordinators. Losing an aging breeder loses the lineage record.
Approval flow	Self-service for own records, but likely 4-eyes at the *species* level — CARES coordinator reviews the breeder's published record before it counts toward the coverage-gap stat on the public dashboard.
Volume	1–5 edits/month per breeder; long tail of breeders each with low volume

Tier-model gap flagged: Current model assumes every Tier 3+ user has an `Institution`. For a single-breeder hobbyist program, either (a) we auto-create a 1-person Institution record per breeder (messy — clutters the Institution admin), or (b) we introduce a concept of "unaffiliated contributor with institution-scoped rights on their own records." Architecture needs to pick one before BE-08-B's queryset scoping is written. Recommend (a) for Gate 08 (lower schema churn); revisit post-MVP.

Persona C — Field Program Lead ("Durrell Nosivolo / Fish Net Madagascar lead")

Attribute	Value
Role	In-country program lead running surveys on the Nosivolo or similar
Tier	3 (Conservation Coordinator), scoped to their `FieldProgram.lead_institution`
Institution type	`ngo` / `research_org`
Entities edited	`FieldProgram` (status, partners), `Survey` (date, site, methodology), `OccurrenceRecord` (bulk after a trip), `SpeciesLocality` (exact coords at Tier 3+). Occasional `BreedingRecommendation` notes on repatriation.
Primary context	**Mixed — critical for form design.** Desktop for post-trip bulk entry (30–200 occurrences at once). Phone/tablet offline in the field for single-point entry; syncs on return.
Friction today	Collects on paper or KoboToolbox; re-keys into GBIF-bound spreadsheets; generalized vs exact coordinates handled by hand.
Approval flow	Self-service for survey + occurrence; Tier 5 admin signs off on the GBIF publish event per the `conservation-status-governance.md` Requirement 3b pre-publish check.

Volume	Bursty — near-zero between trips, 100+ records in a week post-trip

Tier-model fit: **clean**, but form design must account for offline/low-bandwidth bulk entry. This is the only persona where phone-in-field is a first-class use case. Architecture should decide now whether Gate 08 ships offline-capable forms or punts to Gate 09.

Persona D — Conservation Coordinator / IUCN SSC Freshwater Fish Specialist Group

Attribute	Value
Role	Triages status changes, submits `manual_expert` assessments, resolves status conflicts
Tier	3 (for species in their SSC remit) + escalation to Tier 5 for conflict resolution
Institution type	`research_org` or `ngo`; many are cross-institutional
Entities edited	`ConservationAssessment` (source=`manual_expert`, `recommended_revision`), flags assessments for review. May edit Species common names / notes but **not** `iucn_status` directly (mirror policy).
Primary context	Laptop at desk; occasionally laptop at a workshop (ABQ, SSC meetings) — expected to demo the workflow live at ECA June 2026
Friction today	IUCN Red List submission workflow is its own portal; local expert opinions die in email threads. The `manual_expert` path from governance doc is the fix.
Approval flow	Per `conservation-status-governance.md` decision 3: Tier 5 can create-and-accept manual_expert in one step. Tier 3 creates under_revision; Tier 5 accepts. Conflicts follow Requirement 4.
Volume	1–5 assessments/month; spike around Red List assessment cycles

Tier-model fit: **clean.** This persona is the exact driver of the conservation-status-governance spec.

Persona E — Aleksei / Platform Admin (interim)

Attribute	Value
Role	Launch-phase owner per governance memory note; deprovisions users, resolves conflicts, approves registrations, runs imports
Tier	5
Institution type	n/a — cross-institutional
Entities edited	Everything, including User management, Institution records, bulk data imports
Primary context	Desktop; will be on laptop at ABQ workshop June 1–5 triggering `/api/revalidate` during demos (per Gate 07 reconciliation §3 item 3)
Friction today	Django admin is the current CRUD surface. Friction is mostly at the *onboarding* step — approving a new Tier 3 user today is a manual `is_active=True` + `access_tier=3` +

	`institution=…` click.
Approval flow	Self-service; is the ultimate approver for others
Volume	Low but blocking — if Aleksei is offline, everyone else is blocked

Tier-model fit: clean. But flag: single-admin bus factor. Post-workshop handover (governance memory note) needs a second Tier 5 before June.

Cross-persona observations

- **Only one persona (B, hobbyist) has a tier-model gap.** Architecture should resolve before BE-08-B lands.
- **Three of five personas primarily edit records tied to their own institution;** institution-scoping is load-bearing, not cosmetic (see §2).
- **Two personas (C, D) need a "submit → pending review → accept" flow.** The `review_status` field on `ConservationAssessment` already does this; generalize the pattern for `OccurrenceRecord` so Tier 3 field leads can publish without a second Tier 5 step but still be reviewed.
- **Mobile/offline is only required for Persona C** (field lead). PM should scope whether Gate 08 includes it or defers.

Section 2 — Threat model for Tier 3/4 scoping

Each subsection: the attack, what BE-08-B must enforce, and whether it's a Gate 08 blocker (**BLOCKER**) or post-MVP hardening (**HARDEN**).

2.1 Sensitive locality coordinates (Tier 3+)

Per `CLAUDE.md` sensitive-data rules, exact coords are Tier 3+ only; below Tier 3 coords are generalized (GBIF protocols).

Attack	Defense	Class
Tier 3 user at Institution A queries `/api/v1/localities/?species=<rare endemic>` for a species their institution has zero interest in, to sell/publish exact coords (poaching or unauthorized publication).	**Institution-scoped queryset for exact coords:** a Tier 3 user sees exact coords only for localities tied to (a) a `FieldProgram` their institution leads or partners on, (b) an `ExSituPopulation` at their institution for that species, or (c) species they've been explicitly granted via a `SpeciesAccessGrant` (new model? — flag to Architecture). Outside that scope they see *generalized* coords like Tier 2. **Never return exact coords in a list endpoint**; force retrieval through `/localities/<id>/` so every exact-coord read is logged.	**BLOCKER**
Tier 3 user enumerates `/localities/?bbox=…` at high zoom to reconstruct the exact-coord set from allegedly generalized output.	Generalization must be done **server-side at the database layer** (PostGIS `ST_SnapToGrid` with a coarse grid before serialization), not in the serializer layer. Never return both exact and generalized in the same response.	**BLOCKER**

Tier 2 researcher abuses the generalized endpoint to do high-frequency bbox sweeps that, combined with occurrence dates, re-identify a specific survey site.	Rate-limit Tier 2 bbox queries; cap page size; strip `eventDate` precision below day-level for endangered-species occurrences.	**HARDEN**
Audit log itself leaks coords (via `before`/`after` JSON in `AuditEntry`) when a low-tier user queries audit history.	Audit entries for `SpeciesLocality` must redact coord fields when served below Tier 3. Or: locality audit stays Tier 5-only (simpler, matches current phase-1 scope in governance spec §6). Recommend the latter.	**BLOCKER**

Institution-scoping vs tier-only: tier-only is insufficient for locality data. BE-08-B must implement per-record institution scoping, not just "Tier 3 can see all localities."

2.2 Breeding recommendations + genetics (Tier 4)

Attack	Defense	Class
A Tier 4 user at a commercial aquarium (theoretical — no such user exists yet but the tier is institution-agnostic today) scrapes `BreedingRecommendation` + studbook data to identify high-value specimens for private acquisition.	Tier 4 access is scoped to `Institutions` the user has a membership relationship with. A Tier 4 account at Institution A cannot list studbook records for Institution B even for the same species. Cross-institution studbook views are Tier 5 only.	**BLOCKER**
A Tier 4 user exports genetic diversity notes for a species and publishes them, undermining future pedigree confidence.	Genetics fields (`genetic_diversity_notes`, pedigree records) emit an audit entry on *read* for Tier 4, not just on write. Gives Aleksei (Tier 5) a forensic trail if an export shows up in the wild.	**HARDEN**
Bulk CSV export endpoint leaks genetics without individual audit.	Bulk export is a separate permission (`can_bulk_export`, off by default even for Tier 4); gated to specific Tier 4 users by Tier 5 grant.	**BLOCKER** (if bulk export ships in Gate 08)

2.3 Manual ConservationAssessment creation — mirror-policy backdoor

Context: the governance spec adds `source=manual_expert`; Tier 3 creates `under_revision`, Tier 5 accepts; accepted row drives the `Species.iucn_status` mirror. Threat: a malicious Tier 4 (or compromised Tier 3) uses this path to covertly downgrade a species' status.

Attack	Defense	Class
Tier 3 creates a `manual_expert` row with `category='LC'` for a CR species; Tier 5 accepts without noticing.	Acceptance workflow must show the **diff** — current accepted category vs proposed — with an explicit "I have reviewed this change" checkbox before the `accepted` transition is allowed. Tier 5 cannot accept without the diff view being rendered.	**BLOCKER**

Tier 4 user crafts an API POST directly to `/assessments/` setting `source=manual_expert` and `review_status=accepted` in one shot, bypassing the under_revision state.	Serializer must **server-side enforce** the initial state machine: `review_status` is not writable on create for `manual_expert` — always forced to `under_revision` regardless of payload. Tier 5-only PATCH with `review_status=accepted` is the only path to accept.	**BLOCKER**
Admin edits `Species.iucn_status` directly via Django admin or raw ORM.	Governance spec Requirement 3a already covers this (readonly_fields + DEBUG assertion). Verify BE-08-B does not accidentally add a writable serializer surface for `iucn_status` in the coordinator UI. Explicit negative test case.	**BLOCKER**
Tier 3 user targets a species *outside* their institution's scope (no ExSituPopulation, no FieldProgram) to move its status.	`manual_expert` creation must require the user have at least one of: (a) a population record for that species at their institution, (b) a field program with that species as focal, (c) a Tier 5 grant. Otherwise 403.	**BLOCKER**

2.4 Institution-scoping — disgruntled former coordinator

Attack	Defense	Class
A Tier 3 coordinator leaves their institution; account not deprovisioned; they continue editing.	Login flow re-resolves `user.institution` and `user.access_tier` on each session refresh (not just at login); a nightly Celery task flags accounts with no login in 90 days and demotes to Tier 1. Tier 5 must explicitly re-approve a demoted account.	**BLOCKER** for session re-resolve; **HARDEN** for the 90-day sweep
Former coordinator's API token still valid.	Token expiry ≤ 7 days with refresh; revocation endpoint. No "forever" tokens.	**BLOCKER**
Coordinator's institution FK is changed (they move from Institution A to Institution B); they continue editing A's records during the transition.	All institution-scoped querysets key off `user.institution_id` at request time, not a cached value. Changing `user.institution` cuts access to the old institution on the next request. Former-institution data is read-only via audit history.	**BLOCKER**
Shared login among zoo staff (the "everyone uses the curator's login" antipattern).	Not technically preventable, but: enforce per-user email, show "last login from IP X at time Y" on the dashboard so sharing is visible; audit entries attributed to the single account expose the shape of the problem.	**HARDEN**

2.5 CSRF + session hijacking (CRUD UI)

Attack	Defense	Class

CSRF on state-changing endpoints from the Next.js frontend.	Django's CSRF middleware on session-auth endpoints; SameSite=Lax cookies; explicit `X-CSRFToken` header on all non-GET from the frontend. **Do not** disable CSRF for the API just because the frontend is decoupled. Token-auth endpoints are separate and require `Authorization: Token ...` — no cookie, no CSRF surface.	**BLOCKER**
Session cookie theft via XSS in coordinator UI.	HttpOnly + Secure cookies; strict CSP (scripts only from self + Vercel's domain); sanitize all user-entered notes/descriptions before rendering; no `dangerouslySetInnerHTML` on any user-sourced field.	**BLOCKER**
Session fixation / long-lived sessions.	Session TTL ≤ 12 hours for Tier 3+; re-auth required for (a) tier-upgrading actions (Tier 5 accepting a manual_expert), (b) bulk export, (c) user management.	**BLOCKER** for 12h TTL; **HARDEN** for step-up re-auth
Password-based login only, no MFA.	MFA (TOTP) required for Tier 4 and Tier 5; optional for Tier 3.	**HARDEN** (strongly recommended pre-launch to any real institutional data; can slip to Gate 09 if Aleksei accepts the risk for a thin-user-base MVP).

2.6 Audit-log tamper resistance

The `audit` app exists (`AuditEntry` in `backend/audit/models.py`) with save/delete raising `PermissionError` . What it must guarantee in Gate 08:

Requirement	Class
Append-only at the application layer (already implemented).	Done
Append-only at the DB layer: production DB user for the web process has `INSERT`-only grants on `audit_entry`; `UPDATE`/`DELETE` denied. A separate migration user has DDL rights. This is a **deployment** concern BE-08-B cannot fully enforce from code; flag to Architecture.	**BLOCKER** at deploy; **HARDEN** in code (document the grant)
Every Tier 3+ mutation on `ExSituPopulation`, `ConservationAssessment`, `SpeciesLocality`, `BreedingRecommendation`, `Transfer` emits an `AuditEntry`. Expand phase-1 scope from the governance spec (which covered only Species/ConservationAssessment) to include these.	**BLOCKER**
Audit entries capture: actor, tier at time of action, institution at time of action, before/after, IP, user-agent. Current model has actor and before/after; add `actor_tier_at_action` and `actor_institution_at_action` as denormalized fields so a later tier demotion doesn't rewrite history.	**BLOCKER**
Bulk operations emit one audit entry per affected row (not one per bulk).	**BLOCKER**
Audit reads are Tier 5 only except for the Tier 3 scoped view (governance spec decision 2).	**BLOCKER**

2.7 Additional vectors flagged but not deep-dived

- **IDOR on direct object references** in CRUD endpoints (e.g., `PATCH /populations/<id>/` without ownership check). **BLOCKER** — standard DRF permission classes on every ViewSet.
- **Mass assignment** via DRF serializer fields that shouldn't be writable (e.g., `institution` on `ExSituPopulation` — changing this would move a record between institutions). Explicit `read_only_fields`. **BLOCKER.**
- **Race condition on `review_status` acceptance:** two Tier 5 admins accept two conflicting `manual_expert` rows simultaneously. Use `select_for_update` in the mirror-write path. **HARDEN.**
- **Registration-flow abuse:** public registration defaults to `is_active=False` (already done in model); Tier 5 must approve + assign tier + institution. Rate-limit registration endpoint. **BLOCKER.**

Hard-requirements checklist (for security-reviewer when BE-08-B lands)

1. ☐ Exact-coord endpoints enforce per-institution scoping via queryset, not just tier check.
2. ☐ Generalized coords produced server-side via PostGIS `ST_SnapToGrid`; exact and generalized never in same response.
3. ☐ Locality list endpoints return generalized only; exact requires per-record fetch.
4. ☐ Tier 4 genetics/breeding data scoped to user's institution; cross-institution views require Tier 5.
5. ☐ `source=manual_expert` creation forces `review_status=under_revision` server-side regardless of payload.
6. ☐ `review_status=accepted` transition is Tier 5-only and requires a diff-ack.
7. ☐ `manual_expert` creation requires the user have demonstrable interest (population / field program / grant) in the species.
8. ☐ `Species.iucn_status` is never writable via any API serializer (readonly at field level + negative test).
9. ☐ Session refresh re-resolves `user.institution` and `user.access_tier` from DB, not from cached claims.
10. ☐ Institution-scoped querysets key off request-time `user.institution_id`, not cached values.
11. ☐ Token expiry ≤ 7 days with refresh; revocation endpoint exists.
12. ☐ CSRF enforced on session-auth endpoints; `SameSite=Lax`; HttpOnly + Secure cookies.
13. ☐ CSP restricts scripts to self + Vercel; no `dangerouslySetInnerHTML` on user-sourced fields.
14. ☐ Session TTL ≤ 12h for Tier 3+.
15. ☐ Step-up re-auth for Tier 5 accept / bulk export / user management.
16. ☐ Audit scope extended to ExSituPopulation, SpeciesLocality, BreedingRecommendation, Transfer; one entry per row in bulk ops.
17. ☐ AuditEntry records `actor_tier_at_action` and `actor_institution_at_action` (new fields — migration).
18. ☐ Production DB grant denies UPDATE/DELETE on `audit_entry` for the web process user (documented in deploy runbook).
19. ☐ Every ViewSet has an explicit permission class; no DRF default-allow.
20. ☐ `read_only_fields` on every serializer includes ownership-linking FKs (`institution`, `species`, `created_by`).
21. ☐ Registration endpoint rate-limited; new users default `is_active=False`.

22. [ ] MFA enforced for Tier 4+ (or explicitly deferred to Gate 09 with risk-accept signed by Aleksei).

Open questions for Aleksei

1. **Hobbyist breeder modeling (Persona B).** Auto-create a 1-person Institution per CARES breeder, or introduce an "unaffiliated contributor" concept? Architecture needs this before BE-08-B.
2. **Offline/mobile form support for Persona C (field lead).** Gate 08 scope or defer to Gate 09? This is the biggest scope-shaping decision for FE-08.
3. **`SpeciesAccessGrant` model?** For cross-institution collaborators (e.g., an IUCN SSC assessor covering species at 5 institutions they don't belong to). Introduce now, or overload `partner_institutions` on FieldProgram?
4. **MFA pre-launch or Gate 09?** Strong recommendation to ship MFA before any real Tier 4 user is onboarded. Acceptable to slip?
5. **Bulk export permission granularity.** Is there a Gate 08 use case for bulk export at all, or is it Gate 09+? If Gate 08, it needs its own permission flag.
6. **Second Tier 5 admin before workshop.** Governance memory flags bus-factor risk. Who? (Rashel or Jim were named in Gate 07 reconciliation.) Without a second Tier 5, the conflict-resolution and manual_expert-acceptance flows have a single point of failure.
7. **Does the SHOAL partnership conversation at ABQ (June 1–5) realistically add a persona?** If SHOAL becomes a data partner, a "SHOAL Priority Reviewer" persona may need Tier 3-ish cross-institution rights — flag as post-workshop addendum, do not build speculatively now.